



ISC 互联网安全大会



360 互联网安全中心

移动智能终端个人隐私保护技术探索和应用

罗升阳 OPPO架构师

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China
(原中国互联网安全大会)



ISC 互联网安全大会



360 互联网安全中心

目录

个人隐私风险现状盘点

恶意应用窃取

非恶意应用滥用

保护个人隐私技术探索和应用

优化权限管理

打破常规，有的放矢

行业探索

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360 互联网安全中心

个人隐私风险现状盘点

恶意应用窃取

非恶意应用滥用

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

恶意应用窃取



虽然2015-2017年，移动恶意程序进入稳定增长期，即便如此，形势依旧十分严峻

757.3 万

2017新增恶意应用数

1566.7 万人

2017月均感染用户数

1779.3 万人次

2017月均感染次数

数据来源：互联网公开报告《2017年手机安全报告》

ZERO TRUST SECURITY



恶意应用窃取



根据OPPO数据统计，平均每天近10%用户安装应用，为近1%的用户识别恶意应用并保护，相当于**每10个用户就有1个遭遇安装恶意应用风险**



数据来源：OPPO内部统计

ZERO TRUST SECURITY

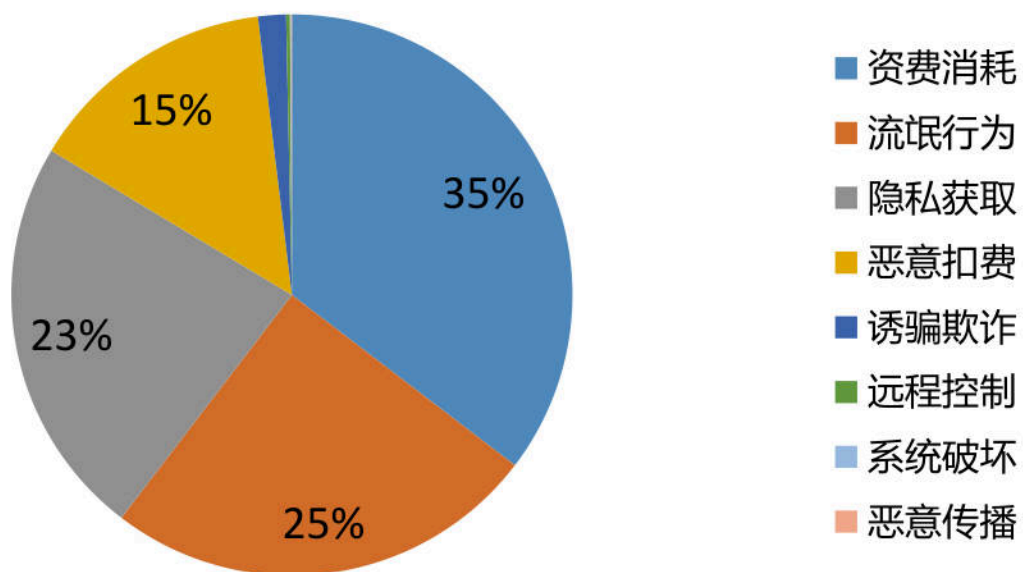
WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

恶意应用窃取



比较突出的恶意应用类型为：资费消耗、流氓行为、**隐私获取**

2018年第一季度手机病毒八大类型占比



数据来源：腾讯移动安全实验室2018年第一季度手机安全报告

ZERO TRUST SECURITY

恶意应用窃取



ISC 互联网安全大会



360 互联网安全中心

隐私获取

安装后窃取用户手机内容上传到指定服务器，**窃取内容**一般包括
电话号码、IMEI、地理位置、联系人、通话记录、短信和相片等

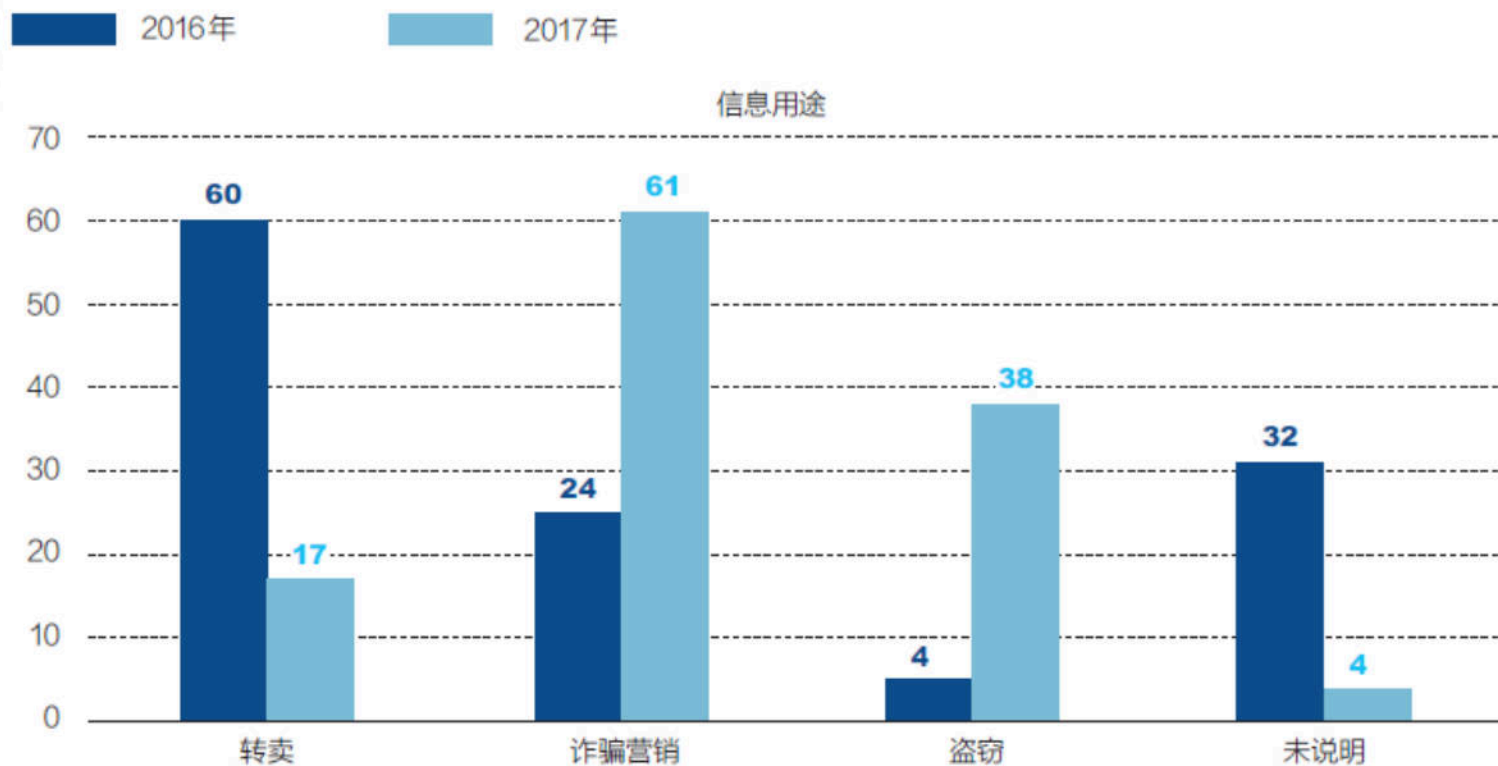
ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

恶意应用窃取



个人隐私窃取后的去向



单位: 案例(个)

资料来源:《财经》记者根据过去3年间261份公开司法判例整理 制图: 颜斌

ZERO TRUST SECURITY

IDENTITY AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China



ISC 互联网安全大会



360 互联网安全中心

恶意应用 !

非恶意应用 ... ?

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

非恶意应用滥用



非恶意应用越界获取隐私权限的风险问题比较突出

2016 年，互联网数据中心 DCCI 和 360 联合发布《2016 年中国 Android 手机隐私安全报告》

指出 **30.2%** 的 Android 手机 App 越界获取了隐私权限。

隐私权限包括（共 15 项）：

读取位置信息、读取手机号码、读取联系人、读取通话记录、读取短信记录、读取彩信记录、打电话、发短信、打开摄像头、使用话筒录音、应用列表、打开 WiFi 开关、打开数据开关、打开蓝牙开关、获取设备信息等

ZERO TRUST SECURITY



非游戏类 越界获取 核心隐私权限 出现较大幅度增长

- “通话记录” 由3.2%增长到**6%**
- “读取彩信记录” 由0.2%增长到**14.3%**

游戏类 获取 普通隐私权限 较大增长

- “获取设备信息” 由94.8%增长到**96%**
- “打开 WiFi 开关” 由65.5%增长到**91%**
- “打开数据开关” 由56.9%增长到**71%**

教育类 获取 重要隐私权限 普遍增长

- “使用话筒录音” 由65%增加到**68%**
- “打开摄像头” 由53%增加到**74%**
- “发送短信” 由11%增加到**13%**

直播类 越界获取 各种隐私权限 有所增加

- “位置信息” 由2.0%增加到**4.5%**
- “访问联系人” 由1%增加到**3.7%**
- “使用话筒录音” 由1%增加到**1.2%**

非恶意应用滥用



ISC 互联网安全大会



360 互联网安全中心

非恶意应用权限风险问题不仅不利于用户使用，还会使用户对权限管理变得“麻木”

越界获取

应用没说清，用户看不懂，不知道应用所谓何用，不知道禁止是否有不好的后果

批量获取

权限弹框提示过多，无法一一确认，只好一股脑全部允许

不授权不可用

为了能使用应用的功能，只能被迫允许

ZERO TRUST SECURITY



ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China

非恶意应用不开启权限不允许使用举例 - 用户在知乎对于某主流浏览器的权限讨论

怎么看安卓应用不给权限就不能使用？

[图片] [图片] 都已经如此厚颜无耻了吗？...显示全部

关注问题

写回答

添加评论

分享

邀请回答

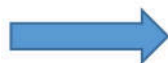
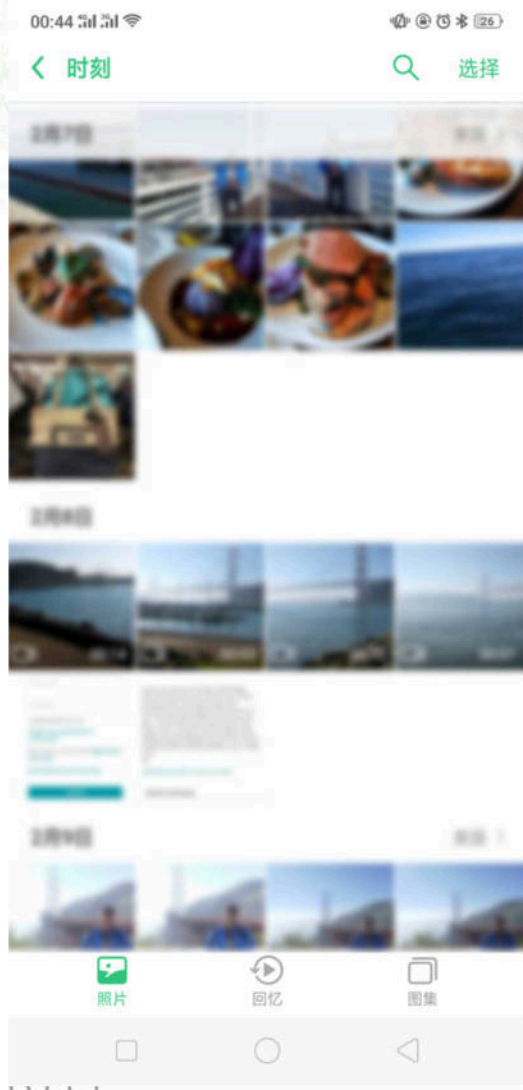
...

在你没有其他替代选项的情况下，你只能接受应用请求的权限。如果你不想授予这些权限，可以找一个具有相同或相似功能的应用。

发布于 2017-01-22

非恶意应用滥用

相册误删除





ISC 互联网安全大会



360 互联网安全中心

保护个人隐私技术探索和应用

优化权限管理

打破常规，有的放矢

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TECHNOLOGY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

优化权限管理

系统除完成自身体验及权限保护优化外，还应该主动影响应用开发者及应用分发平台不断完善



ZERO TRUST SECURITY



系统

- 权限对用户可用易用
 - 名称、说明简单好理解
 - 选项直观，便于控制权限授予
- 保障用户可知可控
 - 权限内容以及风险告知、提示用户确认
- 防止普通权限管控失效
 - 高级权限的约束，如设备管理器、辅助模式
-

优化权限管理



ISC 互联网安全大会

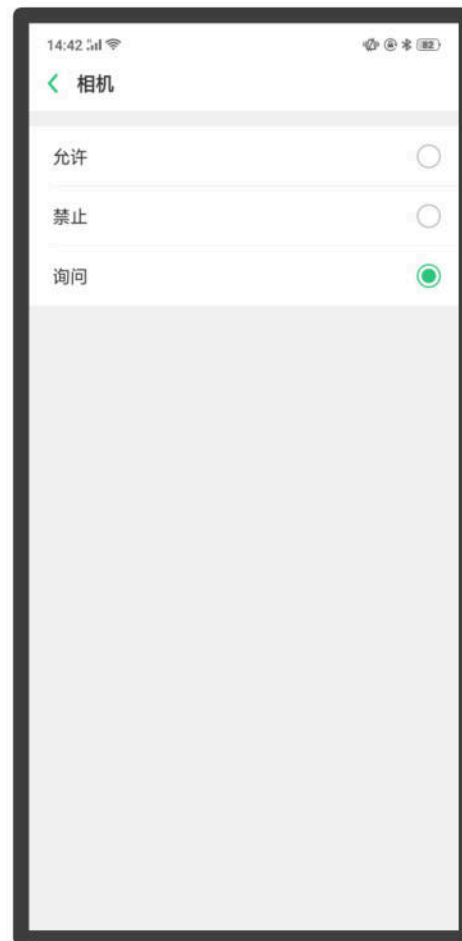


360 互联网安全中心

OPPO系统体验优化举例



用户除分项设置，可对于同类权限打包进行设置



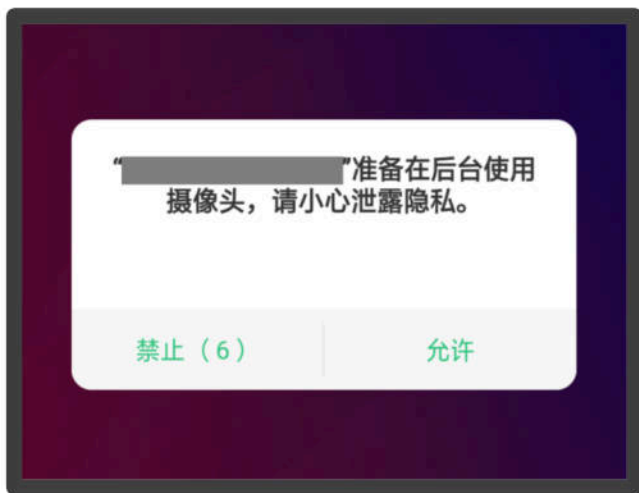
权限设置项用户还可设置询问，避免完全允许后不再受控

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

优化权限管理

OPPO在原生权限管理之外，在应用使用到隐私权限时再次提示，保证用户可知可控



优化权限管理



ISC 互联网安全大会



360 互联网安全中心

OPPO对于关键系统权限针对性进行提示，并增加适度的障碍设置，避免被随意开启



ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

优化权限管理



应用



分发平台

- 分发平台加强检测与审核，包括病毒/广告风险、兼容性等测试，保证向用户分发高质量的应用
- 分发平台对上架应用进行权限风险审核，要求开发者避免权限滥用
- 推动应用开发者在上线应用时同步提交各权限用途说明，并可向用户明示
-

优化权限管理



ISC 互联网安全大会



360 互联网安全中心

OPPO软件商店方案



应用商店中每个应用相关的权限进行说明



应用商店向用户呈现应用安全检测结果，包含病毒、广告等

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

打破常规，有的放矢



ISC 互联网安全大会



360 互联网安全中心

不授权不可用？

16:52 100% 4G

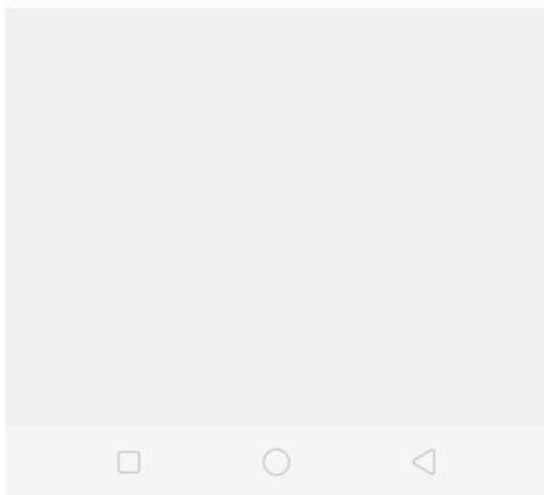
🔊 🔒 🔍 🔔 (55)

← 保护个人信息

保护真实信息不泄露

在应用需要读取以下个人信息时系统将提供空信息，避免真实信息泄露

- 📞 保护通话记录 5 个应用开启 >
- 👤 保护联系人 4 个应用开启 >
- 💬 保护信息 3 个应用开启 >
- 📅 保护日程 2 个应用开启 >



ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

打破常规，有的放矢

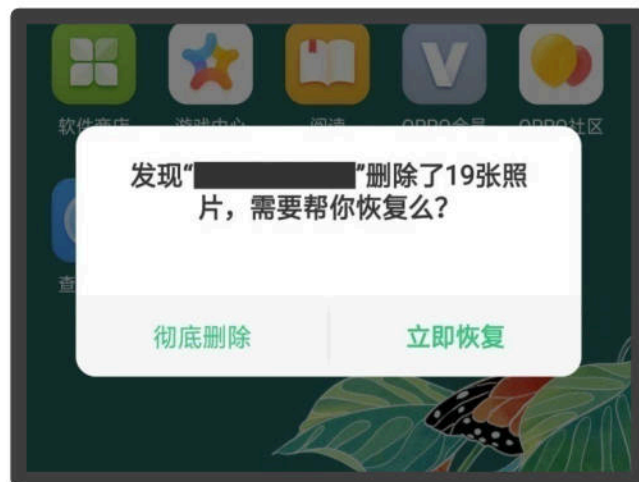


ISC 互联网安全大会



360 互联网安全中心

相册误删除？



ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会

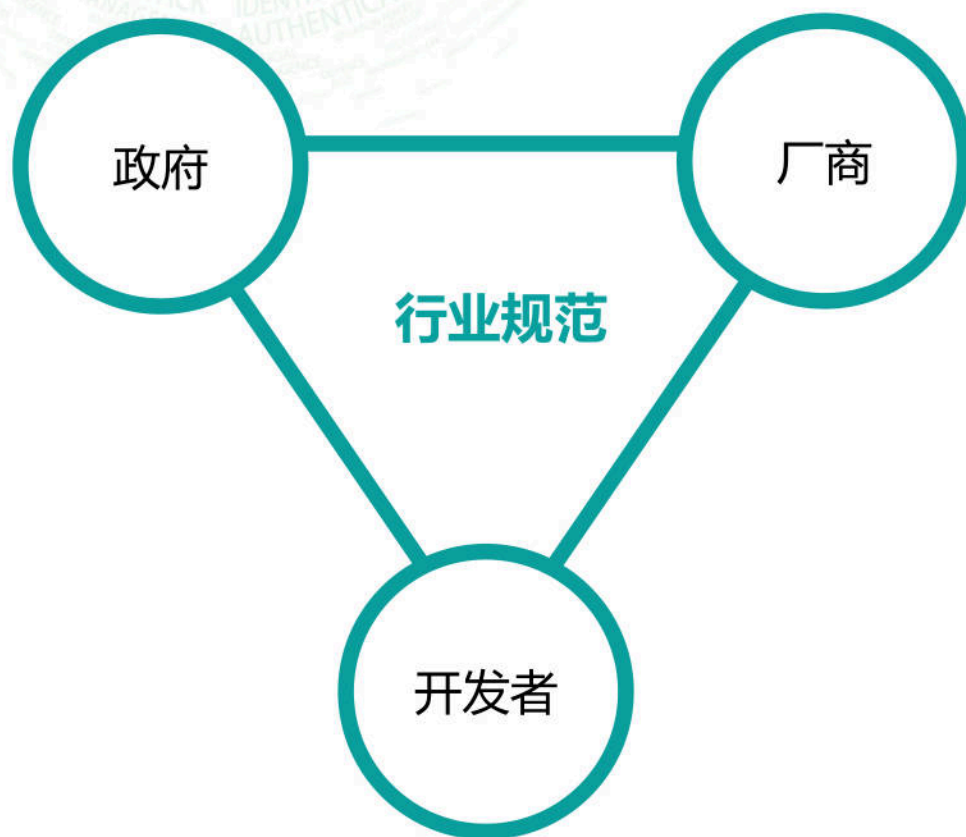


360 互联网安全中心

行业探索

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL INFORMATION



- 自律公约签署
- 技术研究分享、讨论
- 协会标准
-

以行业统一的权限标准，进一步促进应用安全生态发展

OPPO参与立项

《移动智能终端与应用软件用户个人信息保护实施指南

第5部分 终端权限管理》

期待与大家一起交流意见



ISC 互联网安全大会



360 互联网安全中心

谢谢！

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)